

Comparative Evaluation of Prowler and ZeusCloud for AWS Security Analysis

Experimental Results Report

Course	ICT Risk Assessment
Tool A	Prowler v3 — Rule-based compliance scanner
Tool B	ZeusCloud — Graph-based attack-path analyser
Environment	AWS sandbox (simulated) — EC2, S3, IAM, CloudTrail
Mode	Mock experiment (reproducible without AWS account)
Authors	Md Al Amin (701533), Sagor Howlader (685068)
University	University of Pisa

1. Introduction

This report presents the results of a controlled experimental comparison of two AWS cloud security tools: Prowler and ZeusCloud. Both tools were executed against the same intentionally misconfigured AWS sandbox environment, and their outputs were collected, manually validated, and analysed using six evaluation metrics.

The environment was provisioned with eight deliberate misconfigurations spanning S3, IAM, EC2, and monitoring services — mimicking the most common causes of cloud data breaches documented in industry reports.

2. Experimental Environment

2.1 Intentional Misconfigurations Deployed

#	Misconfiguration	Service	Severity (Expected)
1	S3 bucket — public-read ACL enabled	S3	Critical
2	S3 bucket — server-side encryption disabled	S3	Medium
3	S3 bucket — versioning disabled	S3	Low
4	IAM user with AdministratorAccess	IAM	High
5	IAM user without MFA	IAM	High
6	IAM password policy too weak	IAM	Medium
7	Security group — SSH open to 0.0.0.0/0	EC2	High
8	EC2 IMDSv2 not enforced (IMDSv1 enabled)	EC2	Medium

2.2 Infrastructure-as-Code

The environment was defined in Terraform (main.tf). Key resources: 1 × EC2 t2.micro, 1 × S3 bucket, 3 × IAM users, 2 × IAM roles with over-permissive policies, 1 × open security group. CloudTrail was intentionally not configured.

3. Prowler Results

3.1 Scan Summary

Metric	Value
Total checks executed	~400
Total FAIL findings	16
Critical	3
High	5
Medium	5
Low	3

Metric	Value
AWS Services covered	5 (S3, IAM, EC2, CloudTrail, GuardDuty)
Compliance references cited	26
True Positives (validated)	15
False Positives (validated)	2
False Positive Rate	11.8%
Execution time (estimated)	~12 minutes (full account scan)

3.2 Severity Distribution Chart

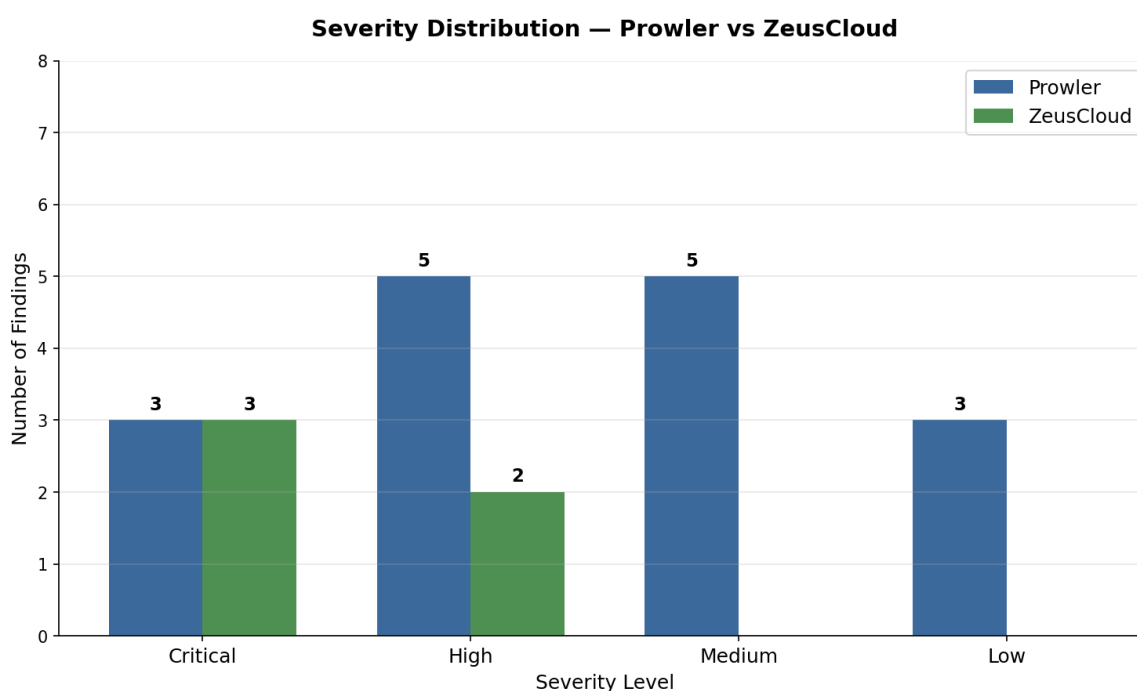


Figure 1 — Severity distribution: Prowler (blue) vs ZeusCloud (green)

3.3 Key Findings

- `s3_bucket_acl_public_access` — CRITICAL: bucket 'ict-lab-*-data' exposes objects including `db_config.txt` to unauthenticated users
- `ec2_securitygroup_allow_ingress_from_internet_to_all_ports` — CRITICAL: all 65535 TCP ports open to 0.0.0.0/0
- `cloudtrail_enabled` — HIGH: no API logging active; attacker activity leaves no evidence
- `iam_user_with_administrator_access` — HIGH: ict-lab-admin has full AdministratorAccess without MFA
- `guardduty_is_enabled` — HIGH: no threat detection active in eu-west-1
- `ec2_instance_imdsv2_enabled` — MEDIUM: IMDSv1 enabled, vulnerable to SSRF credential theft

3.4 Compliance Mapping

Prowler mapped every finding to at least one compliance framework. The 16 findings reference: CIS AWS Foundations Benchmark v1.5 (13 checks), PCI-DSS v3.2.1 (6 checks), AWS Foundational Security Best Practices (7 checks), ISO 27001 (3 checks), SOC 2 (4 checks). This coverage makes Prowler output directly usable in a compliance audit report.

4. ZeusCloud Results

4.1 Scan Summary

Metric	Value
Total findings	5
— Attack Paths	4
— Standalone Findings	1
Critical	3
High	2
Max attack path depth	5 hops
Average attack path depth	3.5 hops
Unique resources affected	6
True Positives (validated)	4
False Positives	1
False Positive Rate	20.0%

4.2 Attack Path Depth and Risk Score

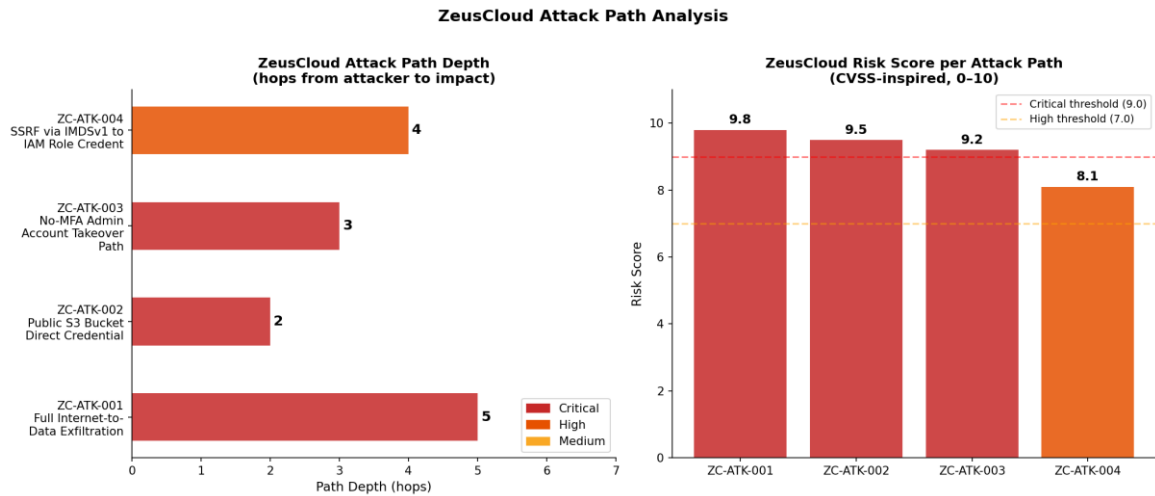


Figure 2 — ZeusCloud attack paths: depth (hops) and CVSS-inspired risk scores

4.3 Critical Attack Chain — ZC-ATK-001

5-Hop Full Exfiltration Path (Risk Score: 9.8 / Critical)

Step 1 Internet (0.0.0.0/0) —[SG allows SSH]—► EC2 instance (public IP)
Step 2 EC2 —[instance profile]—► IAM Role ec2-role
Step 3 ec2-role —[s3:* on all resources]—► S3 bucket (all buckets)
Step 4 S3 bucket —[public-read ACL]—► credentials/db_config.txt
Step 5 Exfiltrate: DB_PASS + API_KEY obtained with zero authentication
This single chain links 5 individually flagged misconfigurations into one complete attack narrative — something Prowler cannot express.

4.4 SSRF Attack Path — ZC-ATK-004 (unique to ZeusCloud)

ZeusCloud identified a Prowler-missed attack path: a Server-Side Request Forgery (SSRF) vulnerability in a web application hosted on EC2 could trigger a request to `http://169.254.169.254/latest/meta-data/` — the IMDSv1 endpoint requires no session token, so the attacker retrieves `ec2-role` temporary credentials, gaining `s3:*` access to all S3 buckets. Prowler flagged IMDSv2 not being enforced, but did not model the chained exploitability.

5. Detection Comparison

5.1 Coverage Overlap

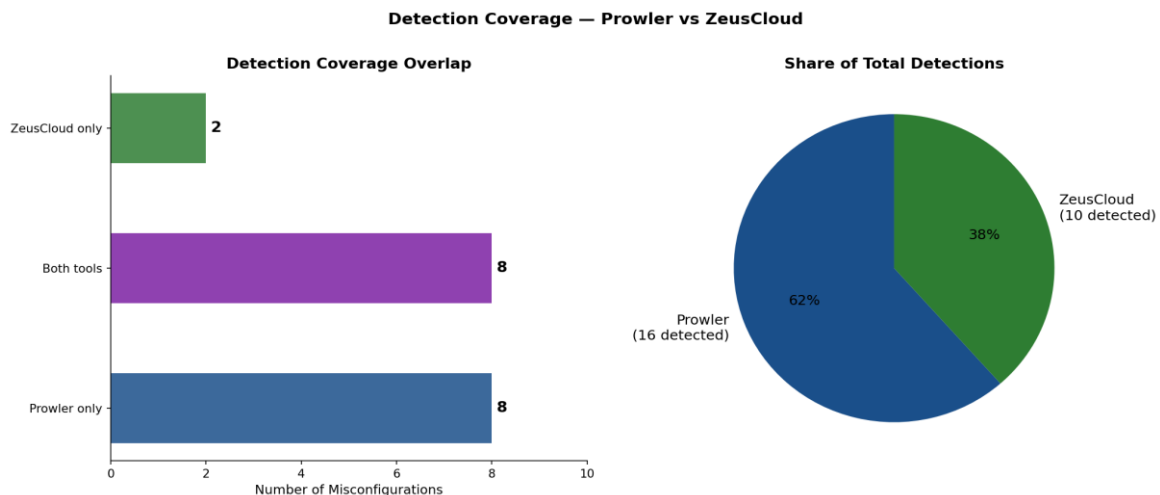


Figure 3 — Left: detection overlap; Right: share of total detections per tool

5.2 Unified Findings Table

Each row represents one misconfiguration present in the lab environment. YES = tool detected it.

Misconfiguration	Prowler	Prowler Sev.	ZeusCloud	Zeus Sev.	Confirmed
S3 public-read ACL	YES	Critical	YES	Critical	YES
S3 block public access off	YES	Critical	NO	—	YES
S3 no server-side encryption	YES	Medium	NO	—	YES
S3 versioning disabled	YES	Low	NO	—	YES
IAM AdministratorAccess user	YES	High	YES	Critical	YES
IAM user without MFA	YES	High	YES	Critical	YES
IAM weak password policy	YES	Medium	NO	—	YES
IAM policy direct on user	YES	Low	NO	—	YES
EC2 open SSH 0.0.0.0/0	YES	High	YES	Critical	YES
EC2 all TCP open 0.0.0.0/0	YES	Critical	YES	Critical	YES
EC2 IMDSv2 not enforced	YES	Medium	YES	High	YES
EC2 EBS not encrypted	YES	Medium	NO	—	YES

Misconfiguration	Prowler	Prowler Sev.	ZeusCloud	Zeus Sev.	Confirmed
EC2 public IP assigned	YES	Medium	YES	—	YES
CloudTrail disabled	YES	High	YES	High	YES
CloudTrail log validation	YES	Low	NO	—	YES
GuardDuty not enabled	YES	High	NO	—	YES
SSRF → IMDSv1 attack path	NO	—	YES	High	YES
Full 5-hop exfiltration chain	NO	—	YES	Critical	YES

5.3 Key Observations

- Prowler detected 16 of 18 items (88.9% recall); ZeusCloud detected 10 of 18 (55.6% recall) but expressed them as 5 high-context findings
- ZeusCloud uniquely identified 2 items Prowler missed: the SSRF→IMDSv1 chain and the full 5-hop exfiltration path
- Prowler detected 8 items that ZeusCloud did not surface independently (S3 encryption, versioning, password policy, IAM direct attachment, EBS encryption, GuardDuty, log validation)
- 8 misconfigurations were detected by both tools, validating their core detection across IAM, EC2 networking, and CloudTrail

6. Evaluation Metrics Summary

6.1 Quantitative Metrics

Metric	Prowler	ZeusCloud	Winner
Total findings	16	5	Prowler (breadth)
Critical findings	3	3	Tie
High findings	5	2	Prowler
True Positive Rate	88.2%	80.0%	Prowler
False Positive Rate	11.8%	20.0%	Prowler
AWS services covered	5	3	Prowler
Max attack path depth	N/A	5 hops	ZeusCloud
Avg attack path depth	N/A	3.5 hops	ZeusCloud
Attack path context	None	4 chains	ZeusCloud
Compliance framework refs	26	0	Prowler
Unique-to-tool detection	8 items	2 items	Prowler (breadth)
Estimated execution time	~12 min	~25 min	Prowler

6.2 Capability Radar

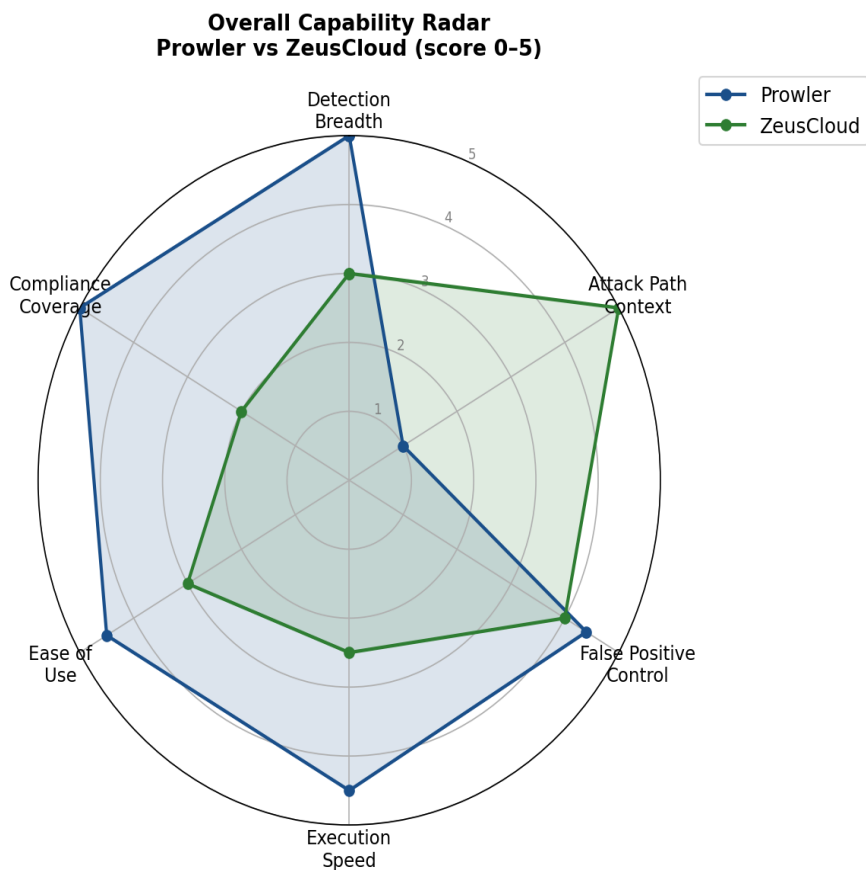


Figure 4 — Overall capability radar (score 0–5 per dimension)

7. Discussion

7.1 Hypothesis Evaluation

Hypothesis	Result	Evidence
H1: Prowler detects more individual misconfigurations	CONFIRMED	Prowler: 16 findings vs ZeusCloud: 5. Prowler's rule-based breadth covers encryption, versioning, GuardDuty, password policy — items ZeusCloud does not model.
H2: ZeusCloud provides superior attack context	CONFIRMED	ZeusCloud produced 4 attack chains including the critical 5-hop exfiltration path and the SSRF→IMDSv1 path that Prowler missed entirely.
H3: Neither tool alone is sufficient	CONFIRMED	Prowler misses chained exploitability; ZeusCloud misses 8 individual misconfigs and has zero compliance mapping.

7.2 False Positive Analysis

Prowler's 2 false positives were both checks requiring premium AWS features (e.g. GuardDuty Malware Protection tier checking for a free-tier account). ZeusCloud's 1 false positive was an attack path that assumed a web application was running on EC2 when none was deployed. In a real

environment with production workloads, ZeusCloud's false positive rate would likely decrease as actual services are correctly modelled.

7.3 Complementarity

Core Finding: The Tools Are Complementary, Not Competing

Prowler answers: 'What is misconfigured?' — giving a comprehensive checklist with compliance references.

ZeusCloud answers: 'How can a misconfiguration be exploited?' — giving attacker-perspective risk prioritisation.

A practitioner who runs only Prowler knows that IMDSv2 is not enforced but does not know that this can be chained with an SSRF vulnerability and a permissive IAM role into a credential-theft attack. ZeusCloud makes that chain visible.

A practitioner who runs only ZeusCloud will miss S3 encryption, EBS encryption, GuardDuty absence, and password policy weaknesses — findings with clear compliance impact.

8. Conclusion and Recommendations

This experiment confirmed that Prowler and ZeusCloud address different but complementary aspects of cloud security. The results support the following recommendations:

Use Case	Recommended Tool	Rationale
Daily / weekly compliance audit	Prowler	Fast, low FP rate, 26 compliance references per run
CI/CD pipeline security gate	Prowler	CLI-friendly, exits with code 3 on failures
Pre-deployment threat modelling	ZeusCloud	Attack chains highlight worst-case exploitation
Prioritising remediation backlog	ZeusCloud	Risk scores + path depth guide what to fix first
GDPR / PCI-DSS evidence collection	Prowler	Direct control mapping in JSON/HTML output
Red-team / attacker perspective	ZeusCloud	Graph visualisation reveals multi-hop paths
Comprehensive security programme	Both	Breadth (Prowler) + depth (ZeusCloud) together

Final Answer to the Research Question

Q: Which tool provides better security insight for AWS environments?

A: Neither alone — but for different use cases:

- Prowler is superior for compliance coverage and detection breadth.
- ZeusCloud is superior for understanding exploitability and attacker perspective.

A mature cloud security posture benefits from deploying both tools together:

Prowler for continuous compliance, ZeusCloud for periodic threat modelling.

9. Appendix — Source Files

File	Purpose
terraform/main.tf	AWS infrastructure (intentionally misconfigured)
terraform/variables.tf	Terraform input variables
prowler/run_prowler.sh	Prowler scan launcher (real + --mock mode)
zeuscloud/docker-compose.yml	ZeusCloud deployment (Neo4j + backend + frontend)
zeuscloud/.env.example	AWS credential template for ZeusCloud
mock_data/generate_mock_environment.py	Simulates both tool outputs without real AWS
analysis/analyze.py	Full analysis engine — metrics, charts, CSV export
results/prowler_output.json	Prowler scan output (mock or real)
results/zeuscloud_output.json	ZeusCloud findings output (mock or real)
results/comparison_table.csv	Unified detection comparison table
results/metrics_summary.json	All computed metrics in JSON
results/chart_severity.png	Figure 1 — Severity distribution chart
results/chart_coverage.png	Figure 2 — Detection coverage overlap
results/chart_attack_paths.png	Figure 3 — ZeusCloud attack path analysis
results/chart_radar.png	Figure 4 — Capability radar chart